

Plano de Aula: Autenticação, Segurança e Controle de Acesso para MVPs

Duração: 120 minutos

Público-alvo: Desenvolvedores participando do Hackathon 7FSDT.

Objetivo: Capacitar os times a implementar fluxos de login seguros e controle de acesso baseado em papéis (Professor vs. Aluno) utilizando tecnologias modernas, sem perder tempo reinventando a roda.

Cronograma Resumido

Duração	Tópico	Foco Técnico
15 min	Segurança no Contexto do Hackathon	Escopo do MVP, LGPD básica e modelagem de ameaças.
30 min	Fundamentos de Autenticação Moderna	JWT, OAuth 2.0 e OIDC (OpenID Connect).
35 min	Stack Tecnológica: Acelerando o MVP	BaaS (Firebase/Supabase) e Cloud Identity (AWS/GCP).
25 min	Controle de Acesso e Código Limpo	RBAC, CORS e arquitetura de segurança no Front/Back-end.
15 min	Fechamento e Q&A	Dicas para a demonstração funcional no vídeo.

Detalhamento dos Blocos (Roteiro do Professor)

Bloco 1: Segurança no Contexto do Hackathon (15 min)

- **O Desafio do MVP:** Explicar que, embora seja um Produto Mínimo Viável focado em resolver problemas como produção de conteúdo ou engajamento de alunos, a segurança não pode ser negligenciada. Vazamento de dados de professores ou alunos invalida a viabilidade da solução.
- **Identidade no Ensino Público:** Como gerenciar quem é o professor, quem é o aluno e como lidar com a inclusão digital (usuários com dispositivos limitados).
- **Armadilha Comum:** Alertar sobre o perigo de "hardcodar" credenciais ou criar sistemas próprios de criptografia de senhas durante a pressa da competição.

Bloco 2: Fundamentos de Autenticação Moderna (30 min)

- **Autenticação vs. Autorização:** A diferença clássica (Quem você é vs. O que você pode fazer).

- **O Padrão JWT (JSON Web Tokens):**
 - Anatomia do Token (Header, Payload, Signature).
 - *Prática:* Mostrar o site jwt.io ao vivo e decodificar um token. Explicar por que dados sensíveis nunca devem ir no payload.
 - **Stateless Authentication:** Vantagens do JWT para escalabilidade em ambientes Cloud (como AWS ou Google Cloud) e como ele facilita integrações via APIs RESTful.
- **OAuth 2.0 e OpenID Connect (OIDC):**
 - Explicar o fluxo de *Authorization Code*.
 - Por que usar Social Login (Google, Microsoft) é a melhor estratégia para engajar professores rapidamente e reduzir o atrito no cadastro.

Bloco 3: Stack Tecnológica - Acelerando o MVP (35 min)

- **Backend-as-a-Service (BaaS) como Bala de Prata para MVPs:**
 - **Firebase Authentication / Supabase:** Demonstrar como essas ferramentas resolvem o login em poucas linhas de código. O Supabase é uma excelente alternativa moderna de código aberto (PostgreSQL).
 - **Cloud Identity Providers:** Breve menção ao AWS Cognito e GCP Identity Platform para times que optarem por arquiteturas serverless mais robustas.
- **Integração no Mobile/Web:**
 - Como plugar esses serviços em frameworks como Flutter ou React Native.
 - *Exemplo Prático:* Mostrar um snippet de código limpo isolando a camada de autenticação (aplicando o princípio de Responsabilidade Única do SOLID). Em vez de espalhar lógicas de login pelas telas, criar uma AuthRepository ou AuthService que se comunique com o BaaS.

Bloco 4: Controle de Acesso e Código Limpo (25 min)

- **RBAC (Role-Based Access Control):**
 - Modelagem prática para o Hackathon: Criação de *Roles* (Ex: role: teacher, role: student).
 - Como proteger rotas no front-end dependendo do papel (ex: só o professor vê o botão de "Criar Prova").
 - Como validar esses papéis no back-end (Middlewares).
- **Boas Práticas de Segurança em APIs:**
 - **CORS (Cross-Origin Resource Sharing):** O que é e como evitar que o front-end seja bloqueado durante os testes simples.
 - **Gerenciamento de Segredos:** O uso imperativo de arquivos .env e variáveis de ambiente (nunca commitar chaves de API no GitHub).

Bloco 5: Fechamento, Q&A e Dicas para a Entrega (15 min)

- **Conexão com os Critérios de Avaliação:** A funcionalidade do MVP vale 30% da nota. Uma autenticação que flui perfeitamente, do login até a funcionalidade principal, impressiona muito os jurados.
- **Sessão de Dúvidas:** Abrir para perguntas técnicas das equipes.